COMPTIA SECURITY+ SY0-701 DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.2 · Intrusion Prevention

Mestre CyberSec · **Aula 3.2 — Intrusion Prevention** (5:14) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: IPS: fica INLINE (no caminho) e BLOQUEIA o ataque. Fail-open: se o IPS falha, deixa passar (disponibilidade > segura); fail-close (bloqueia tudo — mais seguro). IDS passivo + inline = 2 modos: detecta e alerta vs barra.

💡 Highlights que a prova CompTIA cobra

- IPS inline BLOQUEIA; IDS passivo SÓ detecta/alerta
- Fail-open = disponibilidade; fail-close = segurança
- Configuração errada de IPS = bloquear negócio real (false positive)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'blocks attacks inline' = IPS
- 'if the device fails it allows traffic'=fail-open

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.2 — Intrusion Prevention)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Sistema de Prevenção de Intrusão (IPS)
Controle de segurança posicionado inline no caminho da rede que inspeciona ativamente o tráfego e bloqueia automaticamente pacotes maliciosos em tempo real, sem intervenção humana.

⚠️ ***Armadilha CompTIA:*** *If the question says 'blocks attacks automatically' or 'inline and stops traffic', the answer is IPS — never IDS. IDS only alerts; IPS blocks.*

• Sistema de Detecção de Intrusão (IDS)
Sistema de monitoramento passivo que analisa uma cópia do tráfego de rede (via port mirror/TAP) para detectar atividades suspeitas e gerar alertas, mas não interrompe o tráfego.

⚠️ ***Armadilha CompTIA:*** *'Detects and alerts but does not block' = IDS. If traffic would be stopped by the device, it is an IPS, not an IDS.*

• Falha aberta (fail-open) (N/A)
Modo de falha do IPS em que, se o dispositivo perder energia ou travar, o tráfego é permitido passar sem restrições, priorizando disponibilidade sobre segurança.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'if the device fails it allows traffic to pass.' This is the correct choice when business availability outweighs the risk of an outage.*

• Falha fechada (fail-closed) (N/A)
Modo de falha do IPS em que, se o dispositivo falhar, todo o tráfego é bloqueado, priorizando segurança e integridade sobre disponibilidade.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'if the device fails it blocks all traffic.' Choose this when the network must never pass uninspected packets, even at the cost of downtime.*

• Implantação inline (no caminho) (N/A)
Posicionamento de rede em que o dispositivo de segurança fica diretamente no fluxo de tráfego entre origem e destino, forçando todos os pacotes a passarem por ele.

⚠️ ***Armadilha CompTIA:*** *Only inline devices can BLOCK traffic. Passive/out-of-band devices can only DETECT. The exam tests this distinction constantly.*

• Monitoramento passivo (N/A)
Modelo de implantação em que o sensor recebe uma cópia do tráfego (via porta SPAN ou TAP de rede) e o analisa sem estar no caminho dos dados, portanto não pode bloquear pacotes.

⚠️ ***Armadilha CompTIA:*** *Passive + alerts = IDS. The exam often uses 'passive' as a synonym for IDS-style monitoring; do not confuse it with inline IPS.*

• Falso positivo (FP)
Alerta disparado por tráfego legítimo e não malicioso que o IPS/IDS identifica incorretamente como um ataque, frequentemente bloqueando tráfego real do negócio.

⚠️ ***Armadilha CompTIA:*** *Tuning questions on the exam: a misconfigured IPS that blocks legitimate transactions is a false positive problem — adjust signatures, do not disable the device.*

• IPS baseado em rede (NIPS)
Appliance de IPS implantado em pontos estratégicos da rede (ex.: entre firewall e switch core) para inspecionar e bloquear tráfego malicioso para segmentos inteiros.

⚠️ ***Armadilha CompTIA:*** *Compare with HIPS (host-based). On the exam, 'inline at the perimeter blocking attacks' = NIPS; 'agent on a single server' = HIPS.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 NIDS vs. NIPS: O Alarme Passivo vs. O Segurança Armado na Porta

🏠 **Analogia Intuitiva:** Imagine a entrada de uma casa de eventos: o NIDS (Detecção) é como uma câmera de segurança com detector de movimento na parede. Se ela vê um invasor arrombando a janela, ela faz soar uma sirene estridente e envia um e-mail para a polícia, mas ela não tem braços nem pernas para impedir o ladrão de pegar o dinheiro e fugir. O NIPS (Prevenção) é o segurança gigante parado fisicamente dentro do batente da porta: se alguém puxa uma faca, ele agarra a pessoa pelo braço na hora, bloqueia a passagem e joga a faca no lixo.

🔍 **Causa Raiz / Por que foi criado:** O NIDS monitora cópias de tráfego passivamente sem introduzir lentidão na rede, mas é incapaz de impedir o ataque antes que o primeiro pacote danifique o alvo. O NIPS fica posicionado diretamente no fluxo de dados (inline) e descarta pacotes maliciosos em tempo real, porém se falhar ou travar pode interromper toda a comunicação da empresa (fail-closed).

🛡️ **Visão do Auditor de GRC:** Verificar se o NIPS está configurado com bypass automático (hardware bypass / fail-open) para falhas catastróficas de energia e se o conjunto de regras passa por testes periódicos para evitar bloqueio inadvertido de transações comerciais legítimas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'security device positioned inline with network traffic that actively drops malicious packets in real time'. Resposta: NIPS. Se for 'monitors a mirrored copy of network traffic and sends alerts without stopping traffic' -> NIDS.

📌 Topologias de Captura: Em Linha (In-Band / Inline) vs. Fora de Banda (Out-of-Band / TAP / Port Mirroring)

🏠 **Analogia Intuitiva:** In-band / Inline é como colocar uma catraca no meio de um corredor estreito: todo mundo é obrigado a passar por dentro dela e parar. Out-of-band com Port Mirroring ou TAP é colocar um espelho no teto do corredor refletindo a imagem para uma sala ao lado: as pessoas correm livremente pelo corredor sem nenhuma fila, enquanto um guarda na sala ao lado assiste ao reflexo pelo espelho.

🔍 **Causa Raiz / Por que foi criado:** Equipamentos inline precisam tomar decisões de permitir ou bloquear o tráfego instantaneamente. Quando a equipe de segurança quer apenas coletar evidências forenses, auditar tráfego ou evitar o risco de derrubar links de produção de alta velocidade (100 Gbps), utiliza-se espelhamento de portas (SPAN) ou TAP de fibra óptica passivo.

🛡️ **Visão do Auditor de GRC:** Avaliar se portas SPAN e dispositivos TAP possuem controles de acesso físico e de rede estritos, garantindo que o tráfego sensível espelhado não seja interceptado por invasores locais.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'switch feature configured to send a duplicate copy of all traffic on port 1 to an analysis device connected to port 2'. Resposta: Port Mirroring / SPAN (Switched Port Analyzer). Se for hardware físico dedicado que duplica feixe óptico -> Network TAP.

📌 Mecanismos de Detecção: Assinatura vs. Heurística vs. Comportamental (Anomalia)

🏠 **Analogia Intuitiva:** Detecção por Assinatura é o segurança com um álbum de fotos de criminosos conhecidos na mão: se o rosto bater exatamente com a foto do álbum, ele apita (se o vírus for novo e não estiver no álbum, passa direto). Detecção Heurística é o segurança que desconfia de quem usa óculos escuros e capuz dentro do banco em dia nublado (ele usa regras lógicas de 'se parece com perigo, pode ser perigo'). Detecção Comportamental é o sistema que conhece a rotina da sua avó: ela sempre saca 100 reais às terças-feiras; se de repente a conta dela tentar transferir 500.000 reais para a Romênia às 3 da manhã, o sistema bloqueia porque desviou drasticamente da linha de base normal.

🔍 **Causa Raiz / Por que foi criado:** Ataques de Dia Zero (Zero-Day) e malwares polimórficos não possuem assinaturas conhecidas no momento do ataque. Por isso, mecanismos comportamentais criam uma Linha de Base (Baseline) estatística para identificar anomalias sem depender de listas prévias de vírus.

🛡️ **Visão do Auditor de GRC:** Conferir o cronograma de atualização das assinaturas de IDS/IPS (mínimo diário); auditar o processo de treinamento e recalibração das linhas de base comportamentais para minimizar falsos positivos.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'engine detects zero-day attacks by establishing a baseline of normal network activity and alerting on statistically significant deviations'. Resposta: Behavioral / Anomaly-based Detection.

📌 Erros de Classificação: Falsos Positivos vs. Falsos Negativos

🏠 **Analogia Intuitiva:** Falso Positivo é o alarme de incêndio do escritório que dispara ensurdecedoramente só porque alguém queimou uma torrada no micro-ondas: não há perigo real, mas causou pânico e atrapalhou o trabalho de todo mundo. Falso Negativo é a casa estar pegando fogo no quarto ao lado e o alarme permanecer completamente silencioso: o perigo real existia, mas o sistema falhou em perceber, gerando dano catastrófico.

🔍 **Causa Raiz / Por que foi criado:** Sistemas de detecção excessivamente sensíveis geram fadiga de alertas (Alert Fatigue) com falsos positivos. Sistemas permissivos demais deixam passar ataques reais (falsos negativos). O ajuste fino (tuning) constante é a tarefa operacional mais crítica do SOC.

🛡️ **Visão do Auditor de GRC:** Avaliar métricas operacionais do SOC (taxa de falsos positivos e tempo médio de resposta - MTTR); fiscalizar se regras de exceção e whitelists foram formalmente autorizadas pela governança de segurança.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'security sensor flags legitimate administrative traffic as a malicious SQL injection attack'. Resposta: False Positive. Se disser 'malicious attack bypassed the sensor without triggering any alert' -> False Negative.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Dispositivo de rede inline que inspeciona o tráfego e descarta ativamente pacotes maliciosos em tempo real	**NIPS (Network Intrusion Prevention System)**
Dispositivo passivo fora de banda que analisa cópias do tráfego e envia alertas aos analistas sem bloquear os fluxos	**NIDS (Network Intrusion Detection System)**
Recurso no switch de rede que envia uma cópia espelhada de todo o tráfego de uma porta para um analisador de protocolo	**Port Mirroring / SPAN**
Método de detecção que compara padrões de bits e sequências hexadecimais contra uma base de ameaças já conhecidas	**Detecção por Assinatura (Signature-based)**
Motor de detecção que define uma linha de base estatística do tráfego normal e alerta ao identificar desvios atípicos	**Detecção Comportamental / Baseada em Anomalia**
Tráfego comercial totalmente legítimo é incorretamente bloqueado pelo firewall como se fosse um ataque	**Falso Positivo (False Positive)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa quer impedir automaticamente tentativas de exploit conhecidas direcionadas aos seus servidores web públicos antes que os pacotes cheguem aos servidores. Qual implantação atende melhor a esse requisito?

A) IDS de rede conectado a uma porta SPAN

B) IPS de rede implantado inline com regras de prevenção

C) IDS baseado em host configurado apenas para detecção

D) Correlação de logs no SIEM com alertas por e-mail

QUESTÃO 2 · CENÁRIO DE EXAME

Uma equipe de segurança já usa um IDS em uma porta espelhada e recebe alertas, mas o CISO agora quer que o tráfego malicioso seja interrompido antes de chegar aos servidores internos, mantendo a visibilidade de detecção. O que a equipe deve implementar?

A) Um sensor IDS passivo adicional em outra porta SPAN

B) Um IPS de rede em modo inline com assinaturas de prevenção habilitadas

C) Um honeypot colocado na DMZ

D) Um coletor NetFlow configurado para relatórios de anomalias

QUESTÃO 3 · CENÁRIO DE EXAME

Um hospital implanta um IPS inline para proteger sua rede clínica. Se o appliance IPS falhar, aplicações críticas para a vida devem permanecer disponíveis, embora a inspeção fique temporariamente indisponível. Qual modo de falha deve ser configurado?

A) Fail-open

B) Fail-closed

C) Monitoramento passivo

D) Detecção apenas por assinatura

QUESTÃO 4 · CENÁRIO DE EXAME

Uma agência governamental exige que nenhum tráfego não inspecionado seja permitido em sua rede classificada. Mesmo se o IPS inline falhar, o tráfego deve ser bloqueado em vez de contornar a inspeção. Qual modo deve ser configurado?

A) Fail-open

B) Fail-closed

C) Modo promíscuo

D) Espelhamento de porta

QUESTÃO 5 · CENÁRIO DE EXAME

Após a implantação de um IPS inline, usuários relatam que um aplicativo de folha de pagamento para de funcionar. Os logs do IPS mostram que uma assinatura foi acionada por uma consulta normal de banco de dados do aplicativo. O que o administrador deve fazer primeiro para restaurar o serviço mantendo a proteção?

A) Validar o evento como falso positivo e ajustar ou criar uma exceção direcionada para essa assinatura

B) Alterar o modo de falha do IPS para fail-closed

C) Mover o IPS para uma porta SPAN sem alterar as assinaturas

D) Desabilitar permanentemente todas as assinaturas relacionadas a tráfego de banco de dados

QUESTÃO 6 · CENÁRIO DE EXAME

Um analista de segurança precisa monitorar o tráfego de rede em busca de atividade suspeita, mas não deve afetar o fluxo de tráfego nem bloquear pacotes. Qual solução deve ser usada?

A) Um IDS de rede implantado passivamente em uma porta SPAN

B) Um IPS de rede implantado inline com regras de descarte

C) Um IPS fail-closed no switch central

D) Um firewall de aplicação web em modo de bloqueio

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa quer impedir que tráfego de comando e controle de malware saia de sua rede. A equipe de segurança deve parar o tráfego antes que ele chegue à internet. Onde um IPS de rede deve ser implantado?

A) Inline no caminho de saída entre a rede interna e a internet

B) Passivamente em uma porta SPAN que espelha apenas o tráfego interno

C) Somente em dispositivos endpoint como um IDS baseado em host

D) Conectado apenas ao SIEM para correlação de eventos

QUESTÃO 8 · CENÁRIO DE EXAME

Uma regra de NIPS inline corresponde a um pacote malicioso, e a ação configurada para essa assinatura é drop. Qual é o resultado esperado?

A) O pacote é bloqueado e um alerta é gerado

B) O pacote é permitido, mas copiado para uma porta de monitoramento

C) O pacote é encaminhado após ser criptografado

D) O pacote é colocado em fila para aprovação do analista antes da entrega

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa de varejo opera um site de e-commerce que deve permanecer disponível mesmo durante raras falhas do IPS. A equipe de segurança aceita o risco de que o tráfego possa ficar sem inspeção por um curto período durante essa falha. Qual configuração está alinhada com essa decisão?

A) Fail-open

B) Fail-closed

C) TAP passivo sem bloqueio

D) Balanceamento de carga entre servidores web

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa quer detectar e bloquear tráfego de worm de rede tentando se espalhar entre VLANs antes que ele se propague. Qual solução atende melhor a esse requisito?

A) Um IPS de rede implantado inline na fronteira das VLANs

B) Um IDS baseado em host instalado em cada servidor

C) Um IDS de rede passivo conectado a uma porta SPAN

D) Um IPS configurado apenas em modo fail-open

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — IPS de rede implantado inline com regras de prevenção

Um IPS implantado inline pode inspecionar o tráfego no caminho e descartar pacotes maliciosos antes que cheguem ao alvo. Um IDS passivo em porta SPAN apenas detecta e alerta, e o modo somente detecção em host não bloqueia exploits de rede. Correlação em SIEM também não previne o ataque em tempo real.

Questão 2: Alternativa B — Um IPS de rede em modo inline com assinaturas de prevenção habilitadas

Para bloquear tráfego inline, um IPS de rede deve ser colocado no caminho e configurado com ações de prevenção. Sensores IDS passivos adicionais, honeypots e analisadores NetFlow fornecem detecção ou visibilidade, mas não conseguem descartar o tráfego malicioso.

Questão 3: Alternativa A — Fail-open

Fail-open permite que o tráfego continue fluindo se o IPS falhar, priorizando disponibilidade sobre segurança durante a falha. Fail-closed bloquearia o tráfego e poderia interromper cuidados críticos. Monitoramento passivo e detecção apenas por assinatura não descrevem o comportamento de falha de um dispositivo inline.

Questão 4: Alternativa B — Fail-closed

Fail-closed bloqueia todo o tráfego se o IPS falhar, garantindo que nenhum tráfego não inspecionado entre na rede protegida. Isso prioriza segurança sobre disponibilidade. Fail-open permitiria a passagem do tráfego, enquanto modo promíscuo e espelhamento de porta são conceitos de monitoramento passivo.

Questão 5: Alternativa A — Validar o evento como falso positivo e ajustar ou criar uma exceção direcionada para essa assinatura

O evento descrito é um falso positivo porque tráfego legítimo da aplicação correspondeu a uma assinatura. O primeiro passo correto é validá-lo e então ajustar a assinatura ou criar uma exceção restrita para permitir o tráfego legítimo enquanto o tráfego malicioso continua bloqueado. Alterar modo de falha, mover para SPAN ou desabilitar todas as assinaturas de banco de dados não resolve o bloqueio ou cria risco excessivo.

Questão 6: Alternativa A — Um IDS de rede implantado passivamente em uma porta SPAN

Um IDS de rede passivo recebe tráfego copiado de uma porta SPAN e apenas detecta e alerta, portanto não afeta o fluxo de tráfego e não consegue bloquear pacotes. Um IPS inline, IPS fail-closed ou WAF em modo bloqueio pode interromper o tráfego, o que não atende ao requisito de não ser disruptivo.

Questão 7: Alternativa A — Inline no caminho de saída entre a rede interna e a internet

Para impedir tráfego malicioso de saída, o IPS deve estar inline no caminho de saída para poder descartar pacotes antes que saiam da rede. Monitoramento passivo via SPAN, IDS baseado em host e correlação apenas no SIEM fornecem visibilidade ou alertas, mas não bloqueiam a conexão de saída em tempo real.

Questão 8: Alternativa A — O pacote é bloqueado e um alerta é gerado

Em um NIPS inline, a ação drop bloqueia o pacote correspondente e normalmente registra ou alerta sobre o evento. Permitir ou copiar o pacote seria comportamento apenas de detecção, criptografia não é relacionada, e a prevenção de IPS inline não espera aprovação manual para cada pacote.

Questão 9: Alternativa A — Fail-open

Fail-open permite que o tráfego contorne o IPS se ele falhar, preservando disponibilidade enquanto reduz temporariamente a inspeção. Fail-closed bloquearia o tráfego e prejudicaria a disponibilidade. TAP passivo e balanceamento de carga não definem o comportamento de falha do IPS nem o tradeoff de segurança aceito.

Questão 10: Alternativa A — Um IPS de rede implantado inline na fronteira das VLANs

Um NIPS inline na fronteira das VLANs pode inspecionar e descartar tráfego de worm antes que ele se espalhe. IDS baseado em host e IDS passivo detectam ou alertam, mas não bloqueiam tráfego entre VLANs inline. Fail-open apenas descreve o comportamento em falha e não fornece prevenção.